

Module 3: Security Frameworks and Risk

Security Frameworks

Security frameworks are guidelines for building plans to mitigate risks and threats to data and privacy, providing a structured approach to implementing a security lifecycle [cite: image_061d00.png].

- **Purpose and Business Alignment:** Their purpose includes protecting personally identifiable information (PII), securing financial information, identifying security weaknesses, managing organizational risks, and aligning security with business goals [cite: image_061d00.png].

Expanded Concept: Frameworks are not one-size-fits-all; organizations adopt frameworks like ISO 27001 or SOC 2 based on their specific industry regulations and operational needs.

Core Components of Security Frameworks

- **Identifying and Documenting Security Goals:** This involves setting clear objectives, such as aligning with regulations like GDPR [cite: image_061d00.png].
- **Setting Guidelines to Achieve Security Goals:** This means developing policies and procedures, like new data handling policies for user requests [cite: image_061d00.png].
- **Implementing Strong Security Processes:** This focuses on designing procedures to ensure compliance, such as handling user data update or deletion requests [cite: image_061d00.png].
- **Monitoring and Communicating Results:** This involves tracking internal networks and reporting potential security issues to relevant personnel [cite: image_061d00.png].

Expanded Concept: Continuous auditing ensures that these components adapt efficiently to newly discovered threats and organizational changes.

Security Controls

- **Definition and Purpose:** Security controls are safeguards designed to reduce specific security risks, such as requiring employees to complete privacy training to minimize data breaches [cite: image_061d00.png]. Both frameworks and controls are crucial for managing security, ensuring a low level of risk, and supporting an organization's security objectives [cite: image_061d00.png].

- *Expanded Concept:* Controls are generally categorized into three types: **Physical** (e.g., locks, cameras), **Technical/Logical** (e.g., firewalls, encryption), and **Administrative** (e.g., corporate policies, training).

The CIA Triad

The CIA triad is a foundational model that helps organizations consider risk when setting up systems and security policies [cite: image_0530dc.png].

- **Confidentiality:** Ensures that only authorized users can access data [cite: image_0530dc.png].
- **Integrity:** Ensures that data is correct, authentic, and reliable [cite: image_0530dc.png].
- **Availability:** Ensures that data is accessible to authorized users when needed [cite: image_0530dc.png].
- *Expanded Concept:* A compromise in any single pillar of the CIA Triad often weakens the entire security posture of an organization, making holistic defense strategies essential.

Assets and Risk

- **Defining Assets:** An asset is an item perceived as having value to an organization, with its value determined by associated costs [cite: image_0530dc.png].
Expanded Concept: Assets can also be intangible, such as a company's reputation, intellectual property, or customer trust.
- **Valuation and Protection:** Assets storing sensitive data, like social security numbers, are more valuable and require tighter security controls compared to publicly available information [cite: image_0530dc.png]. Risk is often calculated as the intersection of an asset's value, the threats acting against it, and its vulnerabilities.

NIST Cybersecurity Framework

- **Overview:** The NIST Cybersecurity Framework is a voluntary framework providing standards, guidelines, and best practices for managing cybersecurity risk [cite: image_0530dc.png].
- **Application:** Security teams use this framework as a baseline to manage short and long-term risk, protecting organizational assets from threat actors, including disgruntled employees who often have access to sensitive information [cite: image_0530dc.png].
- *Expanded Concept:* The NIST framework is organized around five core functions: **Identify**, **Protect**, **Detect**, **Respond**, and **Recover**. This structure provides a complete lifecycle approach to managing cyber threats.